Arquitetura em Nuvem

Automação da Emissão de Certificados de Calibração — Schulz S.A.

Grupo 39 — Adrian David Castillo Marcano · Nícolas Kretzschmar Lange · Rodrigo Mainardes Ribeiro

Projeto Aplicado III — Tema 02 — Entrega AV2 — 02/10/2026

Unidade Curricular	Projeto Aplicado III — UniSENAI/SC
Docente	Prof. MSc. Hugo Menezes Barra
Empresa parceira	Schulz S.A. — Schulz Metrologia (Setor Dimensional), Joinville/SC
Grupo 39	Adrian David Castillo Marcano; Nícolas Kretzschmar Lange; Rodrigo Mainardes Ribeiro
Tema 02	Arquitetura em nuvem para a automação da emissão de certificados de calibração
Entrega	AV2 — Arquitetura em Nuvem — 02/10/2026
Provedor de nuvem	Amazon Web Services (AWS), região sa-east-1 (São Paulo)

Sumário

1. **Especificação da Arquitetura Cloud e Diagrama de Solução** — 1.1 Diagrama de arquitetura em nuvem · 1.2 Mapeamento e justificativa de serviços (Free Tier)
2. **Matriz de Viabilidade Financeira e Gestão de Limites** — 2.1 Mapeamento de cotas e limites do provedor · 2.2 Plano de monitoramento de custos e alertas
3. **Pipeline de Ingestão e Processamento Serverless** — 3.1 Desenho do pipeline de ingestão e emissão · 3.2 Estratégia de persistência e modelagem cloud
4. **Requisitos de Segurança, Autenticação e Conformidade** — 4.1 Gestão de identidade e controle de acesso (IAM) · 4.2 Segurança e proteção de dados (in-transit e at-rest)
5. **Rastreabilidade com a Entrega 01**
6. **Premissas, restrições e pontos a validar**
7. **Referências consultadas**

Nota metodológica e definições de escopo

Este documento projeta a infraestrutura em nuvem que sustenta a Prova de Conceito (PoC) do software especificado na Entrega 01. Ele mantém as duas convenções daquele documento. A primeira é a rastreabilidade: cada decisão de arquitetura aponta para o requisito (RF, RNF), a regra de negócio (RN) ou a anomalia (AN) da AV01 que a justifica, e a Seção 5 consolida essas ligações. A segunda é a marcação explícita do que não é evidência: **[PREMISSA]** indica suposição do grupo e **[VALIDAR]** indica pergunta ainda aberta, ambas reunidas na Seção 6.

Quatro pontos que a AV01 havia deixado em aberto (PV-01, PV-08, PV-09 e PV-10) foram respondidos pela Schulz em 17/09/2026 e passam a ser definições de escopo desta entrega, não mais premissas:

ID	Definição da empresa (17/09/2026)	Consequência na arquitetura
DE-01	Não há integração direta com Calypso nem com LightLab, seja por API, banco de dados ou conector de equipamento. O escopo é a ingestão da planilha Excel/CSV sanitizada no Tema 01.	A porta de entrada é única: o upload do arquivo. Nenhum conector, VPN ou rede privada é necessário, o que elimina os componentes de rede que costumam gerar custo fixo.
DE-02	O operador faz o upload da planilha no storage da nuvem; esse evento dispara a função serverless que lê o arquivo, grava os dados no banco e gera o certificado em PDF.	O pipeline é orientado a eventos, disparado pela criação do objeto no bucket de entrada (Seção 3.1).
DE-03	Assinatura ICP-Brasil não é necessária na PoC, por se tratar de fluxo interno. Usar apenas autenticação de usuário no PDF gerado.	A autoria do certificado é dada pela identidade do usuário autenticado, registrada no documento e na trilha (Seções 4.1 e 4.2).
DE-04	Retenção de 5 anos para os registros, padrão adotado pela empresa com base na ISO/IEC 17025, com regras de ciclo de vida no storage.	Regras de ciclo de vida e bloqueio de exclusão no bucket de certificados (Seções 1.2 e 4.2).

Todas as cotas, limites e regras de serviço citados foram conferidos nas páginas oficiais da AWS em **02/10/2026**; os endereços estão na Seção 7. Onde a página oficial não permitiu confirmar um número, o texto usa um teto conservador e o declara como tal. Um achado dessa conferência altera a leitura do próprio roteiro e é tratado na Seção 2.1: desde 15/07/2025 o Free Tier da AWS para contas novas deixou de ser o modelo de “12 meses grátis” e passou a ser um plano gratuito com créditos, mantendo as cotas permanentes (*Always Free*).

1. Especificação da Arquitetura Cloud e Diagrama de Solução

1.1 Diagrama de arquitetura em nuvem

A Figura 1 apresenta a arquitetura proposta. Ela é integralmente *serverless*: não há servidor, contêiner, banco provisionado por instância nem componente de rede com cobrança por hora. Toda a computação ocorre em funções acionadas por evento e todo o armazenamento está em serviços gerenciados. O arquivo-fonte editável (`diagramas/arquitetura-av02.drawio`) está versionado no repositório do grupo.

O diagrama, na página seguinte, tem três fronteiras. A externa é a conta AWS dedicada à PoC. Dentro dela, a região sa-east-1 (São Paulo) contém todos os recursos que tocam dados da Schulz, e a faixa inferior reúne os serviços globais de governança e custo. Fora da nuvem ficam apenas as pessoas: os usuários internos da Metrologia e os clientes externos que precisam conferir um certificado. O Calypso e o LightLab não aparecem por decisão da empresa (DE-01): o que entra na nuvem é o arquivo, não uma conexão com esses sistemas.

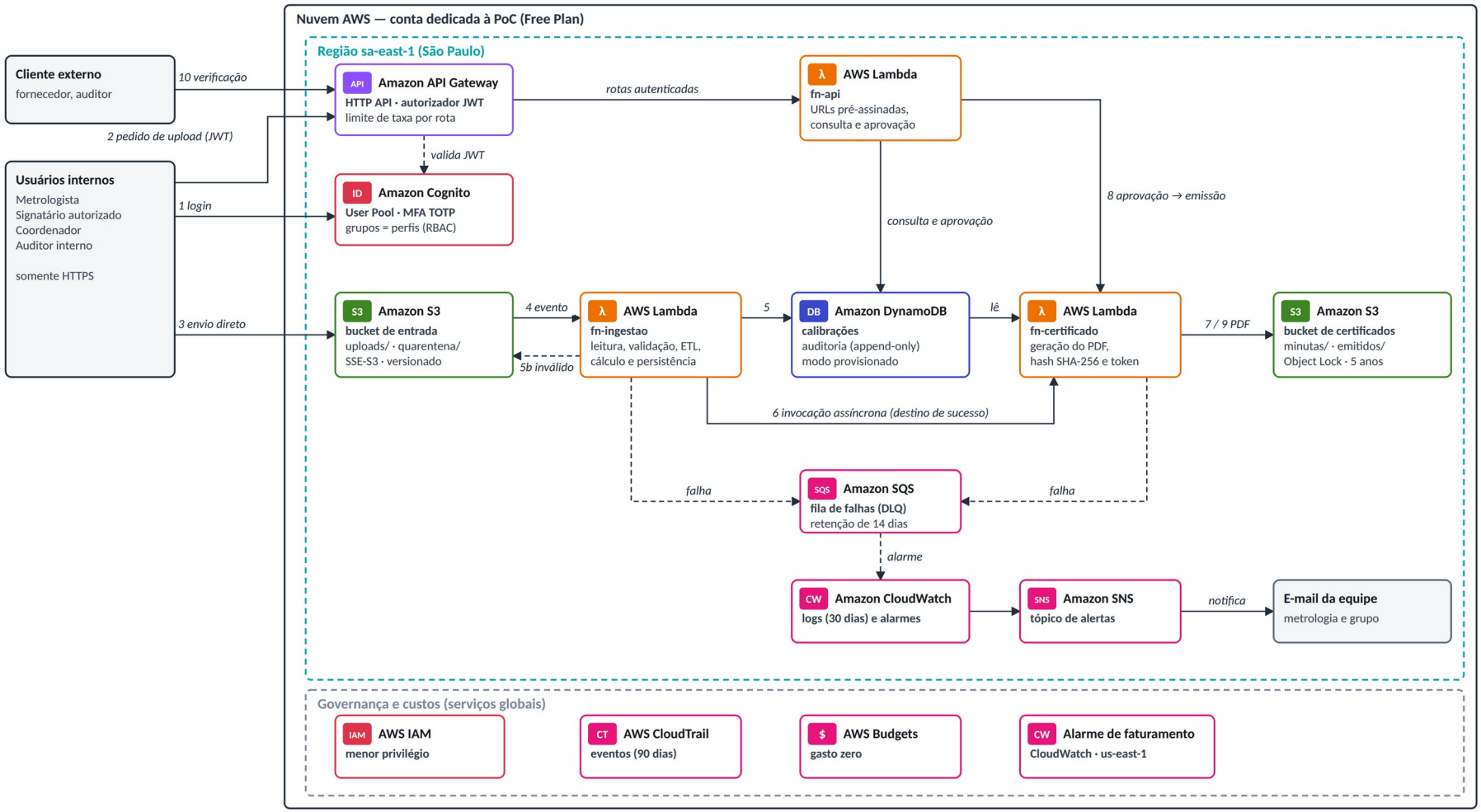


Figura 1 — Arquitetura em nuvem da PoC na AWS: do upload da planilha sanitizada ao certificado em PDF. Os números correspondem aos passos descritos na Seção 1.1.

1.1.1 Leitura do diagrama, passo a passo

Os números a seguir são os mesmos que identificam as setas da Figura 1.

Passo 1 — Autenticação. O usuário interno se autentica no Amazon Cognito com e-mail corporativo, senha e segundo fator por aplicativo autenticador (TOTP). O Cognito devolve um token JWT que carrega a identidade do usuário e o grupo a que pertence — metrologista, signatário, coordenador ou auditor. Esse token é a base de todo o controle de acesso da Seção 4.1 e é o que atende à definição DE-03.

Passo 2 — Pedido de upload. Com o token, o metrologista chama a rota `POST /uploads` do Amazon API Gateway. O autorizador JWT do próprio API Gateway valida assinatura, emissor, validade e grupo antes de qualquer código ser executado; pedidos sem token válido são recusados na borda, sem consumir computação. A função `fn-api` registra a intenção de upload e devolve um formulário de envio pré-assinado, válido por 5 minutos, restrito a um único caminho do bucket, ao tipo de arquivo esperado e a um tamanho máximo de 5 MB.

Passo 3 — Envio direto ao storage. O navegador envia a planilha sanitizada diretamente ao bucket de entrada do Amazon S3, no prefixo `uploads/`, por HTTPS. O arquivo não atravessa a função nem o API Gateway, o que evita os limites de carga desses serviços e mantém o consumo de computação próximo de zero nessa etapa. O usuário nunca recebe credenciais da AWS: recebe apenas a autorização temporária e específica para aquele envio.

Passo 4 — Evento de criação do objeto. A gravação do arquivo gera o evento `s3:ObjectCreated` no prefixo `uploads/`, que invoca de forma assíncrona a função `fn-ingestao`. Esse é o gatilho pedido na definição DE-02 e o ponto em que o processo deixa de depender de ação humana.

Passo 5 — Leitura, validação, saneamento, cálculo e persistência. A `fn-ingestao` calcula o hash SHA-256 do arquivo, valida a estrutura contra o contrato de entrada, aplica as regras de saneamento da AV01, calcula os resultados e a incerteza e grava tudo no Amazon DynamoDB em uma transação. **Passo 5b:** se o arquivo é inválido, nada é gravado nas tabelas de negócio; o objeto é movido para o prefixo `quarentena/` com o motivo da rejeição e a equipe é notificada.

Passo 6 — Encadeamento por evento. O término bem-sucedido da ingestão aciona, por destino de sucesso do AWS Lambda, a função `fn-certificado`. Não há fila sendo consultada nem serviço orquestrador em execução permanente: uma função termina e o resultado dela é o evento que inicia a seguinte.

Passo 7 — Geração da minuta. A `fn-certificado` lê os dados já calculados no DynamoDB, monta o certificado em PDF no layout atual da Schulz e o grava no bucket de certificados, prefixo `minutas/`, com a marcação de documento em revisão.

Passo 8 — Aprovação. O signatário autorizado consulta a minuta e aprova a emissão pela rota `POST /calibracoes/{id}/aprovacao`. A `fn-api` verifica que o aprovador pertence ao grupo de signatários e que não é o técnico executante (RN-12), registra a decisão e aciona novamente a `fn-certificado`.

Passo 9 — Emissão. A `fn-certificado` atribui o número sequencial, gera o PDF definitivo com a identificação de quem executou e de quem aprovou, calcula o hash SHA-256 do documento, grava

o arquivo no prefixo `emitidos/` com bloqueio contra alteração e exclusão (S3 Object Lock) e registra a emissão na tabela de auditoria.

Passo 10 — Consulta, download e verificação. Usuários internos baixam o certificado por um endereço pré-assinado de curta duração, emitido pela `fn-api` após checagem de perfil. O cliente externo — um fornecedor ou um auditor — confere a autenticidade pela rota pública `GET /verificacao/{token}`, que devolve apenas número, data, situação e hash do documento, sem dado pessoal.

Tratamento de falha. As linhas tracejadas mostram o caminho de erro. Se uma função falha depois das tentativas automáticas, o evento é enviado à fila de falhas no Amazon SQS, um alarme do Amazon CloudWatch dispara e o Amazon SNS avisa a equipe por e-mail. Nenhuma planilha se perde em silêncio, que é justamente o defeito do processo atual apontado na AV01 (AN-03, truncamento sem aviso).

1.2 Mapeamento e justificativa de serviços cloud (Free Tier)

A seleção seguiu três critérios, nesta ordem: (i) o serviço precisa estar na cota permanente da AWS ou ter consumo estimado desprezível frente aos créditos do plano gratuito; (ii) não pode haver cobrança por tempo ocioso, porque o laboratório emite cerca de 12 certificados por mês e passa a maior parte do tempo sem tráfego; (iii) deve atender a um requisito não funcional da AV01 sem exigir operação de infraestrutura pela equipe da Metrologia (RNF-12).

1.2.1 Armazenamento — Amazon S3

Dois buckets separados, por função e por segurança. O **bucket de entrada** recebe as planilhas (`uploads/`) e guarda as rejeitadas (`quarentena/`). O **bucket de certificados** guarda as minutas (`minutas/`) e os documentos emitidos (`emitidos/`). A separação não é estética: se a função que é disparada por um bucket gravasse no mesmo bucket, ela se invocaria em ciclo, e esse é o cenário clássico de consumo descontrolado em arquiteturas orientadas a eventos; a documentação da AWS recomenda explicitamente buckets distintos para entrada e saída.

Ambos têm acesso público bloqueado, versionamento ativo e criptografia no servidor. O bucket de certificados tem ainda o **S3 Object Lock**, que implementa o modelo *write once, read many*: um objeto gravado em `emitidos/` não pode ser sobrescrito nem excluído até o fim do período de retenção. É esse mecanismo, e não uma convenção da aplicação, que garante a imutabilidade exigida por RNF-03, RN-15 e RN-22 e que responde ao risco de auditoria RA-06 (registros editáveis).

A definição DE-04 é atendida por regras de ciclo de vida, declaradas por prefixo:

Prefixo	Regra de ciclo de vida	Justificativa
`uploads/`	Retenção de 5 anos e 30 dias; transição para classe de acesso infrequente após 90 dias.	O original importado é parte do registro (RN-22) e permite reprocessar qualquer certificado.
`quarentena/`	Expiração em 90 dias.	Arquivo rejeitado não é registro de calibração; guarda-se o suficiente para a correção e o reenvio.
`minutas/`	Expiração em 30 dias.	A minuta perde a função quando o certificado é emitido ou a calibração é cancelada.
`emitidos/`	Object Lock por 5 anos a partir da emissão;	Retenção definida pela Schulz (DE-04). A

Prefixo	Regra de ciclo de vida	Justificativa
	transição para classe de arquivamento após 12 meses; expiração em 5 anos e 30 dias.	expiração só ocorre depois do fim do bloqueio.
Todos	Versões não correntes expiram em 30 dias; uploads incompletos são abortados em 7 dias.	Evita acúmulo invisível de armazenamento.

Duas ressalvas técnicas, verificadas na documentação. Primeiro, o S3 não transiciona por padrão objetos menores que 128 KB, e um certificado desta família tem cerca de 115 KB (o arquivo real `Cal_1_5896_1_0.pdf` tem 114.788 bytes); a regra de transição só terá efeito sobre os PDFs maiores, a menos que se configure um filtro de tamanho. Segundo, no volume da Schulz a transição é irrelevante em custo: cinco anos de acervo somam cerca de 0,27 GB. As regras foram mantidas porque a empresa as pediu e porque o que elas entregam aqui é governança — prazo de guarda explícito, automático e auditável — e não economia. Na PoC, o Object Lock será usado em modo *governance* com retenção curta, para que o ambiente de testes possa ser limpo; em produção, o modo é *compliance* com 5 anos, em que nem o usuário raiz da conta consegue excluir o documento.

1.2.2 Computação e processamento — AWS Lambda

Três funções, cada uma com um papel de execução próprio (Seção 4.1):

Função	Gatilho	Responsabilidade	Requisitos atendidos
`fn-api`	API Gateway (rotas HTTP)	Emitir autorizações pré-assinadas de upload e download, consultar calibrações, registrar aprovação, verificar token.	RF-12, RF-15, RF-16
`fn-ingestao`	Evento `s3:ObjectCreated` em `uploads/`	Ler e validar o arquivo, sanear, calcular resultados e incerteza, avaliar conformidade e persistir.	RF-01 a RF-09
`fn-certificado`	Destino de sucesso da ingestão e invocação assíncrona pela aprovação	Gerar o PDF (minuta e definitivo), numerar, calcular hash e token, gravar com Object Lock.	RF-10, RF-11, RF-13, RF-14

O Lambda foi escolhido por cobrar apenas por requisição e por tempo de execução: sem upload, o custo e o consumo de cota são zero. A alternativa em contêiner ou máquina virtual manteria um recurso ligado 24 horas para processar 12 arquivos por mês. O serviço também atende ao RNF-12, pois elimina o add-in local e a dependência do arquivo `ReportINI.xls` em XLSTART identificados na AV01. Os limites do serviço — 15 minutos de execução e até 10.240 MB de memória por função — estão muito acima do necessário: a meta do RNF-01 é concluir a importação e o cálculo em até 5 segundos. A divisão em duas funções de pipeline separa o motor de cálculo da geração do documento, que têm bibliotecas, consumo de memória e ritmo de mudança diferentes, e antecipa a decomposição em microsserviços da Entrega 03. A linguagem de implementação é decisão daquela entrega; as estimativas deste documento usam 1 GB de memória por função de pipeline, valor conservador para qualquer das opções.

1.2.3 Banco de dados — Amazon DynamoDB

O DynamoDB é o único banco gerenciado da AWS cuja cota gratuita é permanente: 25 GB de armazenamento e 25 unidades de leitura e 25 de escrita provisionadas. A decisão não é trivial,

porque o dicionário de dados da AV01 é relacional, e por isso é discutida em detalhe na Seção 3.2, com as alternativas descartadas e o custo de modelagem assumido. Em síntese: um banco relacional em instância ficaria ligado continuamente e consumiria créditos mesmo sem uso, enquanto o DynamoDB em modo provisionado tem custo zero dentro da cota e, por construção, não ultrapassa a capacidade contratada.

1.2.4 Segurança e autenticação — Amazon Cognito, AWS IAM e API Gateway

O **Amazon Cognito** fornece o diretório de usuários, a política de senha, o segundo fator e a emissão de tokens, com cota gratuita de 10.000 usuários ativos por mês que, segundo a página de preços, não expira. Ele substitui dois mecanismos frágeis apontados na AV01: a seleção do signatário por índice numérico digitado (AN-22) e o campo de signatário "Não informado" (RA-09). O **AWS IAM** define o que cada função pode fazer, com um papel por função e permissões mínimas. O **Amazon API Gateway**, no tipo HTTP API, é a única porta de entrada para chamadas: termina o TLS, valida o JWT e limita a taxa de requisições por rota. A opção por HTTP API, e não REST API, deve-se ao autorizador JWT nativo e ao menor preço por requisição.

1.2.5 Integração, observabilidade e custos

O **Amazon SQS** é usado apenas como fila de falhas (*dead-letter queue*). O grupo avaliou e descartou o uso de fila como gatilho entre as funções: uma função que consome fila mantém consultas permanentes ao serviço mesmo com a fila vazia, o que gastaria parte da cota mensal sem processar nada. O encadeamento por destino do Lambda não tem esse custo de espera. O **Amazon SNS** envia os alertas operacionais e de custo por e-mail. O **Amazon CloudWatch** recebe os logs das funções, com retenção de 30 dias, e mantém os alarmes. O **AWS CloudTrail** registra as ações administrativas na conta, com histórico de 90 dias sem custo. O **AWS Budgets** e o alarme de faturamento compõem o plano da Seção 2.2.

1.2.6 Serviços deliberadamente não utilizados

Tão importante quanto a lista de serviços escolhidos é a dos evitados, porque são eles os responsáveis usuais por cobrança inesperada: NAT Gateway e VPC com sub-redes privadas (cobrança por hora; desnecessários sem integração de rede, DE-01); bancos em instância, como RDS (ligados 24 horas); chaves gerenciadas pelo cliente no AWS KMS (US$ 1 por chave por mês, sem cota gratuita de armazenamento de chave); concorrência provisionada no Lambda (cobrança por tempo reservado); o modo sob demanda do DynamoDB (não coberto pela cota gratuita, que se aplica ao modo provisionado); envio de SMS para segundo fator (pago por mensagem); e o nível *Plus* do Cognito (sem cota gratuita).

2. Matriz de Viabilidade Financeira e Gestão de Limites (Free Tier)

2.1 Mapeamento de cotas e limites do provedor

2.1.1 O modelo de Free Tier vigente

O roteiro cita cotas "contínuas ou de 12 meses", como "AWS S3 5 GB". Na conferência das fontes oficiais, o grupo constatou que esse modelo mudou. Segundo o comunicado da AWS de 15/07/2025, contas criadas a partir dessa data entram em um novo programa:

- **Plano gratuito (*Free Plan*)**: US$ 100 em créditos na criação da conta e até US$ 100 adicionais por atividades de exploração; validade de 6 meses ou até o fim dos créditos, o que ocorrer primeiro. A documentação afirma que, nesse plano, a conta **não gera cobrança** enquanto não for convertida em plano pago.
- **Cotas permanentes (*Always Free*)**: mais de 30 serviços mantêm limites mensais gratuitos nos dois planos, sem prazo.
- **Contas anteriores a 15/07/2025** permanecem no programa antigo, com as ofertas de 12 meses. Como toda conta desse grupo já tem mais de 12 meses em outubro de 2026, essas ofertas — entre elas os 5 GB do S3 e o primeiro milhão de chamadas do API Gateway — estão vencidas para qualquer conta que o grupo pudesse usar.

A consequência prática é que hoje existem só duas situações possíveis, e a PoC foi desenhada para a mais segura delas: uma **conta nova, dedicada, no plano gratuito** [PREMISSA]. Nela, a garantia de custo zero tem duas camadas independentes. A primeira é a arquitetura: todos os serviços medidos por uso, com exceção de dois, operam inteiramente dentro de cotas permanentes. A segunda é o próprio plano: os dois serviços sem cota permanente (S3 e API Gateway) consomem créditos, não dinheiro, e o plano gratuito não emite fatura. O prazo de 6 meses cobre com folga o calendário da disciplina, cuja última entrega é em 03/12/2026.

2.1.2 Volume estimado da Schulz

As estimativas partem do volume da AV01: cerca de 137 certificados por ano, ou 12 por mês [PREMISSA, PV-05]. Para cada serviço, a matriz mostra também um **cenário de estresse de 10 vezes** esse volume (120 certificados por mês), que cobre a extensão da solução a outras famílias de instrumentos e os testes do grupo. Consumo por certificado emitido:

Grandeza	Composição	Por certificado
Invocações de função	1 ingestão + 2 gerações de PDF (minuta e definitivo) + 10 chamadas de API	13
Tempo de computação	Ingestão: 1 GB × 8 s; PDF: 1 GB × 6 s × 2; API: 0,25 GB × 0,3 s × 10	
Armazenamento permanente no S3	Planilha original (teto de 250 KB) + PDF definitivo (120 KB)	≈ 370 KB
Requisições ao S3	1 envio, 1 leitura, 2 gravações de PDF, 4 downloads	8
Itens no DynamoDB	23 itens de negócio + cerca de 15 eventos de auditoria	≈ 30 KB

Os tamanhos de arquivo vêm dos artefatos reais: a planilha de cálculo tem 201 KB, o relatório da MMC 26 KB e o certificado emitido 115 KB. Os tempos de execução são tetos estimados a partir do RNF-01 e do RNF-02 e serão substituídos por medição na Entrega 03.

2.1.3 Matriz de cotas, consumo e folga

Serviço	Cota gratuita mensal	Natureza da cota	Consumo estimado (12 cert./mês)	Cenário 10× (120 cert./mês)	Uso da cota (10×)
AWS Lambda	1.000.000 de requisições	Permanente	156 requisições	1.560 requisições	0,16%
AWS Lambda	400.000 GB-segundo	Permanente	252 GB-s	2.520 GB-s	0,63%
Amazon DynamoDB	25 GB de armazenamento	Permanente	0,36 MB/mês; 21,6 MB em 5 anos	216 MB em 5 anos	0,86%
Amazon	25 unidades de leitura e	Permanente	23 e 23 alocadas	23 e 23 alocadas	92% alocado;

Serviço	Cota gratuita mensal	Natureza da cota	Consumo estimado (12 cert./mês)	Cenário 10× (120 cert./mês)	Uso da cota (10×)
DynamoDB	25 de escrita provisionadas	(modo provisionado)	(Seção 3.2)		teto fixo
Amazon Cognito	10.000 usuários ativos	Permanente	até 10 usuários	até 30 usuários	0,30%
Amazon SQS	1.000.000 de requisições	Permanente	menos de 100 (apenas falhas)	menos de 1.000	0,10%
Amazon SNS	1.000.000 de requisições e 1.000 e-mails	Permanente	menos de 50 e-mails	menos de 300 e-mails	30% dos e-mails
Amazon CloudWatch	10 alarmes, 10 métricas customizadas, 5 GB de logs	Permanente	5 alarmes; 0 métrica customizada; cerca de 0,5 MB de logs	5 alarmes; cerca de 5 MB de logs	50% dos alarmes; 0,1% dos logs
AWS Budgets	Monitoramento gratuito; 2 orçamentos com ação	Permanente	2 orçamentos, 1 com ação	igual	dentro da cota
Amazon S3	Sem cota permanente para conta nova (5 GB só no programa antigo, por 12 meses)	Créditos do plano gratuito	4,4 MB/mês; 96 requisições	44 MB/mês; 960 requisições	ver 2.1.4
Amazon API Gateway	Sem cota permanente (1 milhão de chamadas só no programa antigo, por 12 meses)	Créditos do plano gratuito	120 chamadas	1.200 chamadas	ver 2.1.4

Leitura da matriz: mesmo no cenário de estresse, nenhum serviço medido por uso passa de 1% da cota. A única linha próxima do limite é a capacidade provisionada do DynamoDB, e isso é intencional — ali a cota não é um consumo que varia, é um teto que o grupo aloca. Capacidade provisionada não “estoura”: quando a demanda supera o alocado, o serviço recusa a requisição excedente em vez de cobrar por ela. O armazenamento projetado para 5 anos de retenção (DE-04) é de cerca de 270 MB no S3 e 22 MB no DynamoDB.

2.1.4 Consumo de créditos pelos serviços sem cota permanente

Para S3 e API Gateway, o grupo calculou o consumo de créditos com **tarifas-teto**, propositalmente acima das tarifas públicas, para que a conclusão não dependa de centavos [VALIDAR na AWS Pricing Calculator para sa-east-1 antes da implantação]:

Item	Quantidade na PoC (teto)	Tarifa-teto adotada	Créditos por mês
Armazenamento no S3	0,2 GB (inclui arquivos de teste)	US$ 0,05 por GB-mês	US$ 0,010
Requisições ao S3	1.000	US$ 0,01 por mil	US$ 0,010
Chamadas ao API Gateway	5.000 (inclui navegação e testes)	US$ 1,50 por milhão	US$ 0,008
Total			≈ **US$ 0,03**

Em 6 meses, o consumo acumulado é de aproximadamente US$ 0,17, ou 0,17% dos US$ 100 de crédito inicial. Valor faturado no período: **R$ 0,00**. Depois da PoC, se a Schulz levar a solução a um plano pago, o custo recorrente desses dois serviços com 5 anos de acervo fica na ordem de US$ 0,02 por mês; todo o restante continua em cota permanente.

2.2 Plano de monitoramento de custos e alertas (Billing Alerts)

O plano tem quatro linhas de defesa. A ideia é que o estouro da camada gratuita precise atravessar todas elas para acontecer, e que cada uma falhe de forma visível.

2.2.1 Primeira linha — o plano da conta

A PoC roda em conta dedicada no plano gratuito. Nessa modalidade não há cobrança: se os créditos acabarem, a conta é suspensa e os dados ficam retidos por 90 dias, em vez de gerar fatura. Para o objetivo desta entrega, isso converte o risco financeiro em risco de disponibilidade, que é aceitável em uma PoC e é coberto pelos alertas abaixo. A conta dedicada também isola a PoC de qualquer outro uso: tudo o que aparecer no painel de custos pertence ao projeto. Regra operacional: **a conta não é convertida em plano pago durante a PoC**, e a conversão exige decisão registrada do grupo.

2.2.2 Segunda linha — limites embutidos na arquitetura

São controles que impedem o consumo, e não apenas o avisam:

Controle	Efeito sobre o custo
Buckets separados para entrada e saída	Impede que uma função se dispare em ciclo, o cenário mais comum de consumo descontrolado.
DynamoDB em modo provisionado, sem escalonamento automático	Capacidade fixa em 23 unidades; demanda excedente é recusada, não cobrada.
Tempo limite por função (30 s na ingestão e no PDF; 5 s na API)	Uma execução travada não consome além do teto; o padrão do RNF-01 é 5 s.
No máximo 2 novas tentativas por evento	Um arquivo defeituoso gera no máximo 3 execuções antes de ir para a fila de falhas.
Limite de taxa no API Gateway (10 requisições por segundo por rota)	Um cliente defeituoso ou mal-intencionado não gera volume de chamadas relevante.
Upload limitado a 5 MB e a um prefixo	Ninguém usa a autorização de upload para armazenar arquivos grandes.
Retenção de logs em 30 dias	Os logs não crescem indefinidamente contra a cota de 5 GB.
Regras de ciclo de vida no S3	Minutas, quarentena, versões antigas e uploads incompletos são removidos automaticamente.

2.2.3 Terceira linha — alertas

#	Mecanismo	Configuração	Ação ao disparar
A-1	AWS Budgets — orçamento de gasto zero	Modelo *Zero spend budget*: notifica quando o gasto real passa de US$ 0,01.	E-mail aos três integrantes; abre o procedimento 2.2.5.
A-2	AWS Budgets — orçamento mensal de custo com ação	Limite de US$ 1,00 por mês, com alertas em 50% do gasto previsto e em 100% do gasto real.	E-mail; em 100%, ação automática de bloqueio.
A-3	Alertas de uso do Free Tier	Ativados nas preferências de faturamento; a AWS avisa quando o uso atinge 85% de uma cota.	E-mail; revisão do serviço apontado.
A-4	Alarme de faturamento no CloudWatch	Métrica `EstimatedCharges` (namespace `AWS/Billing`), limiar maior que US$ 0, criado na região us-east-1, onde a métrica é publicada.	Publica no tópico SNS de custos.
A-5	Alarmes operacionais no CloudWatch	Mensagens na fila de falhas > 0; erros das funções de pipeline > 0; requisições recusadas	Publica no tópico SNS de operação.

#	Mecanismo	Configuração	Ação ao disparar
		no DynamoDB > 0.	

Os alarmes operacionais entram no plano de custos porque são sinais antecipados: erro repetido e requisição recusada indicam consumo anormal antes de ele aparecer no faturamento, que não é atualizado em tempo real. A ação automática do alerta A-2 aplica aos papéis das funções uma política de negação temporária, de modo que o pipeline pare de executar até a revisão humana; a AWS inclui dois orçamentos com ação sem custo. Os dois orçamentos são configurados para medir o custo antes do abatimento de créditos, pois é o consumo de créditos, e não a fatura, o que precisa ficar visível no plano gratuito. O total é de 5 alarmes, dentro dos 10 gratuitos.

2.2.4 Configuração prática

A sequência de implantação, a ser executada na criação da conta e antes de qualquer recurso do pipeline, é: (1) ativar o segundo fator no usuário raiz e criar os usuários administrativos do grupo; (2) nas preferências de faturamento, ativar os alertas de uso do Free Tier e o recebimento de alertas de faturamento pelo CloudWatch; (3) criar o tópico SNS de custos e confirmar a assinatura dos três e-mails; (4) criar os orçamentos A-1 e A-2; (5) criar o alarme A-4 em us-east-1; (6) só então criar buckets, tabelas e funções; (7) registrar em `evidencias/` as capturas de tela de cada item. A criação do primeiro orçamento é, além disso, uma das atividades que a AWS recompensa com crédito adicional. As capturas de tela serão anexadas quando a conta for criada [VALIDAR — ver PV-17].

2.2.5 Quarta linha — rotina e resposta

Um integrante do grupo, em rodízio semanal, confere toda segunda-feira o painel de faturamento, a página de uso do Free Tier e o saldo de créditos, e registra o resultado em uma linha no repositório. Se qualquer alerta de custo disparar, o procedimento é: (1) identificar o serviço no explorador de custos; (2) interromper a origem — desativar o gatilho do bucket ou a rota afetada; (3) conferir a fila de falhas e os logs do período; (4) corrigir a causa e registrar o ocorrido no repositório; (5) reativar. Ao fim da PoC, os recursos são removidos e a conta é encerrada, salvo decisão da Schulz de assumir o ambiente.

3. Pipeline de Ingestão e Processamento Serverless (ETL na Nuvem)

3.1 Desenho do pipeline de ingestão e emissão

3.1.1 Princípios do desenho

O pipeline segue a arquitetura orientada a eventos descrita na definição DE-02 e três princípios derivados da AV01. **Nada é digitado**: o único dado que entra é o arquivo (RN-26), o que elimina a transposição manual de 28 valores por certificado (D-02). **Nada é perdido em silêncio**: todo arquivo termina em um de três estados visíveis — processado, em quarentena ou em falha — em oposição ao truncamento sem aviso da planilha atual (AN-03). **Tudo é reproduzível**: o original é preservado e o cálculo é determinístico e versionado, de modo que qualquer certificado pode ser regenerado a partir do arquivo de origem (RNF-04, RN-31).

O contrato de entrada é a pasta de trabalho sanitizada especificada no Tema 01, em `.xlsx` (inclusive no formato OOXML Strict dos arquivos reais, RNF-13) ou em CSV, conforme DE-01. Ela traz os blocos de medição e os dados mestres da calibração no layout do modelo unificado. O layout exato de abas e colunas é fixado como contrato na Entrega 03 [PREMISSA].

3.1.2 Etapas do pipeline

#	Etapa e componente	O que acontece	Tratamento de erro	Rastreio (AV01)
E1	Autorização de upload — API Gateway e `fn-api`	Valida o JWT e o grupo; devolve formulário pré-assinado para `uploads/{id}/{uuid}.xlsx`, válido por 5 min, com limite de 5 MB.	Sem token ou sem perfil: recusa na borda (401 ou 403), sem execução de função.	RNF-05, RN-21
E2	Envio — navegador e S3	O arquivo é gravado diretamente no bucket de entrada por HTTPS, já criptografado em repouso.	Arquivo fora da política (tipo, tamanho, prazo) é recusado pelo próprio S3.	RF-01, RNF-06
E3	Disparo — S3 e Lambda	O evento `s3:ObjectCreated` em `uploads/` invoca a `fn-ingestao` de forma assíncrona.	Até 2 novas tentativas automáticas; depois, fila de falhas e alerta.	DE-02
E4	Identidade do arquivo — `fn-ingestao`	Calcula o SHA-256 e tenta registrar o hash com gravação condicional.	Hash já existente: o evento é encerrado sem efeito e o usuário é informado da duplicata.	RN-20, R-33, R-34
E5	Leitura e validação estrutural	Confere assinatura do relatório, cabeçalho da tabela, presença de dados e número de blocos de medição.	Estrutura fora do contrato: quarentena com o motivo; nada é persistido.	RF-02, AN-05, AN-08
E6	Saneamento e normalização	Aplica as regras R-07 a R-32: sinais de tolerância, datas, números, unidades, decomposição dos nomes das características.	Domínio não resolvido ou campo obrigatório ausente: quarentena. Nome de característica não reconhecido: segue, sinalizado.	RF-03, RF-04, AN-30, AN-31, RN-23
E7	Cálculo	Média, desvio padrão, erro e limites (R-40 a R-45); orçamento de incerteza, veff, k e U (R-48 a R-50), com o orçamento persistido.	Número de leituras diferente do exigido pelo procedimento: quarentena.	RF-06, RF-07, RN-01 a RN-05, RN-10, AN-17
E8	Conformidade e bloqueios	Classifica cada característica e o status global; verifica validade e identidade do padrão.	Padrão vencido ou divergente do relatório: calibração fica bloqueada para emissão, com o motivo registrado.	RF-08, RF-09, RN-06 a RN-09, AN-02, AN-34
E9	Persistência — DynamoDB	Grava a calibração, medições, características com leituras e resultados e os eventos de auditoria, em transação.	Falha na transação: nada é gravado; o evento é reexecutado e, por E4, não duplica.	RF-05, RF-14, RN-22
E10	Geração da minuta — `fn-certificado`	Monta o PDF no layout atual, sem limite de características, com paginação calculada, e grava em `minutas/`.	Texto com marcador não resolvido (XX, YY, 00/00/0000): geração recusada e registrada.	RF-10, RF-11, RN-16, RN-17, AN-01, AN-24
E11	Aprovação — `fn-api`	O signatário aprova; a gravação é condicional ao estado e à identidade do aprovador.	Aprovador igual ao técnico, ou calibração fora do estado esperado: recusa (409).	RF-12, RN-12, RN-13
E12	Emissão — `fn-certificado`	Numera, gera o PDF definitivo, calcula hash e token e grava em `emitidos/` com Object Lock.	Falha após numerar: a operação é retomada com o mesmo número, sem lacuna nem	RF-13, RNF-03, RNF-09, RN-14, RN-15, RN-36

#	Etapa e componente	O que acontece	Tratamento de erro	Rastreio (AV01)
			duplicidade.	

3.1.3 Garantias do processamento por evento

Idempotência. O S3 entrega eventos com garantia de pelo menos uma vez, e o Lambda pode repetir uma execução que falhou. O pipeline é seguro para repetição por três mecanismos: o hash do arquivo é registrado com gravação condicional (só grava se ainda não existir), de modo que o segundo evento do mesmo arquivo é reconhecido e encerrado; o identificador da calibração é definido antes do upload e está no nome do objeto, o que torna as gravações determinísticas; e a numeração do certificado ocorre na mesma transação que cria o registro do certificado. Reenviar a mesma planilha, por engano ou por repetição do evento, nunca produz um segundo certificado (RN-20).

Quarentena não é falha. O pipeline distingue as duas situações. Quarentena é um resultado de negócio: o arquivo foi lido, está errado e o metrologista precisa corrigi-lo; ele vê o motivo na aplicação e reenvia (UC-06). Falha é um problema técnico: a função não concluiu; o evento vai para a fila de falhas, a equipe técnica é avisada e o reprocessamento consiste em reexecutar o evento guardado na fila. A mistura dessas duas situações é o que torna pipelines difíceis de operar.

Estados. A calibração percorre a máquina de estados da AV01 (RN-13): `IMPORTADO` → `CALCULADO` → `EM_REVISAO` → `EMITIDO`, com os desvios `QUARENTENA`, `BLOQUEADO` e `CANCELADO`. Cada transição é uma gravação condicional ao estado anterior, o que impede, por exemplo, emitir duas vezes ou aprovar uma calibração bloqueada, mesmo com chamadas simultâneas.

Desempenho. O fluxo do upload à minuta é assíncrono e a aplicação consulta o estado da calibração. A meta é RNF-01 (até 5 s para importar e calcular) mais RNF-02 (até 3 s para o PDF). A primeira execução após um período ocioso sofre a partida a frio da função, e o tempo real, com e sem partida a frio, será medido e reportado na Entrega 03.

3.2 Estratégia de persistência e modelagem cloud

3.2.1 Decisão e alternativas

O dicionário de dados da AV01 descreve 17 entidades relacionais, com chaves estrangeiras e restrições de unicidade. A escolha natural seria um banco relacional. O grupo optou pelo **Amazon DynamoDB** e registra a decisão com suas contrapartidas:

Alternativa	Enquadramento na camada gratuita	Avaliação
Amazon RDS (PostgreSQL em instância)	Oferta de 12 meses apenas no programa antigo; em conta nova, consome créditos de forma contínua.	Aderência total ao modelo da AV01, mas instância ligada 24 horas para 12 gravações por mês; exigiria rede privada para acesso seguro a partir do Lambda. **Descartada.**
Amazon Aurora Serverless	Sem cota permanente; consome créditos.	Elasticidade desnecessária para o volume; mesmo problema de rede. **Descartada.**
Amazon DynamoDB	Cota permanente: 25 GB e 25 unidades de leitura e de escrita provisionadas.	Custo zero por construção e sem rede privada. Exige remodelar para acesso por chave e levar a integridade referencial para a aplicação.

Alternativa	Enquadramento na camada gratuita	Avaliação
		Escolhida.

O custo assumido é real e não deve ser minimizado: o DynamoDB não tem junções nem chaves estrangeiras. O modelo abaixo mostra como cada garantia do modelo relacional é reconstruída. O argumento que torna a troca aceitável é a forma do dado: a calibração é um agregado fechado — uma calibração, suas medições, suas características e seu certificado são sempre lidos e gravados juntos — e esse é o caso de uso para o qual o DynamoDB foi desenhado. Para a evolução a produção, o modelo relacional da AV01 permanece como especificação lógica, e a migração para PostgreSQL é possível sem alterar o pipeline, apenas a camada de persistência.

3.2.2 Desenho das tabelas

São duas tabelas. A tabela **`calibracoes`** segue o padrão de tabela única, com chave de partição `PK` e chave de ordenação `SK`:

Entidade (AV01)	PK	SK	Observação
calibracao	`CAL#<id>`	`META`	Estado, datas, referências aos dados mestres
arquivo_importado	`CAL#<id>`	`ARQ#<sha256>`	Nome original, tamanho, chave do objeto
medicao	`CAL#<id>`	`MED#<sequência>`	Plano, data e hora, equipamento
caracteristica, leitura, resultado	`CAL#<id>`	`CAR#<ordem>`	Leituras e resultado embutidos no item
orcamento_incerteza e componentes	`CAL#<id>`	`ORC`	Cópia do orçamento usado, com versão (RN-31)
certificado	`CAL#<id>`	`CERT#<número>#REV#<n>`	Hash, token, chave do PDF, autoria
instrumento	`INSTR#<tag>`	`META`	Dados mestres do mensurando
padrao e certificado_padrao	`PADRAO#<código>`	`META` e `CERT#<número>`	Validade consultada em RN-06
procedimento, criterio_aceitacao, solicitante	`PROC#...`, `CRIT#...`, `SOLIC#...`	`REV#<n>` ou `META`	Revisão congelada na calibração (RN-33)
Restrições de unicidade	`HASH#<sha256>`, `TOKEN#<token>`, `CERTNUM#<número>`	`UNICO`	Itens-sentinela com gravação condicional
Sequência anual do certificado	`SEQ#CERT#<ano>`	`CONTADOR`	Incremento atômico (RN-14)

A tabela **`auditoria`** tem `PK = <entidade>#<id>` e `SK = <instante ISO 8601>#<identificador>`, e guarda quem fez, o quê, quando e o estado antes e depois. A separação em tabela própria é a forma de tornar a trilha realmente imutável (RNF-04): os papéis das funções recebem nessa tabela apenas a permissão de inserir, sem alterar e sem excluir (Seção 4.1), e a tabela tem proteção contra exclusão ativada.

A entidade `usuario` da AV01 não vira tabela. A identidade vive no Cognito; as tabelas guardam apenas o identificador opaco do usuário e, no certificado emitido, o nome que precisa constar do documento. É uma aplicação direta da minimização exigida por RNF-07 e RN-35.

3.2.3 Padrões de acesso e índices

Consulta	Como é atendida	Requisito
Carregar uma calibração completa	Uma consulta por `PK = CAL#<id>`	RF-10, RF-15
Histórico de certificados de um instrumento, por TAG	Índice GSI1: `INSTR#<tag>` + data da calibração	RF-15, RF-22
Fila de trabalho por estado e certificados por período	Índice GSI2: `STATUS#<estado>` + data	RF-12, RF-20
Busca pelo número do certificado	Leitura direta do item `CERTNUM#<número>`	RF-15
Verificação pública de autenticidade	Leitura direta do item `TOKEN#<token>`	RF-16
Arquivo já importado?	Gravação condicional do item `HASH#<sha256>`	RN-20
Trilha de um certificado	Consulta na tabela `auditoria` pela chave da entidade	RF-14, RNF-04

A capacidade provisionada é alocada assim: `calibracoes` com 10 unidades de leitura e 10 de escrita; GSI1 e GSI2 com 4 e 4 cada; `auditoria` com 5 e 5. Total de 23 de leitura e 23 de escrita, dentro das 25 gratuitas. Uma emissão grava cerca de 40 itens de até 1 KB; como a gravação é transacional, consome o dobro, perto de 80 unidades, que a tabela absorve em poucos segundos com a capacidade de rajada acumulada nos períodos ociosos.

3.2.4 Compatibilidade com o dicionário de dados da AV01

- **Precisão numérica.** A AV01 exige `NUMERIC(18,7)` para preservar as 7 casas da MMC (R-31). O tipo numérico do DynamoDB é decimal exato, com até 38 dígitos de precisão; não há conversão para ponto flutuante binário, e o arredondamento ocorre apenas na apresentação (RN-18).
- **Datas.** Os campos `TIMESTAMPTZ` são gravados como texto ISO 8601 em UTC, que ordena corretamente como chave de ordenação.
- **Enumerações.** Estados, tipos e perfis são validados pela aplicação contra os domínios da AV01 antes da gravação.
- **Unicidade.** Cada restrição `UNIQUE` da AV01 vira um item-sentinela gravado na mesma transação que o item principal; se o sentinela já existe, a transação inteira é desfeita.
- **Integridade referencial.** A existência do instrumento, do padrão, do procedimento e do critério é conferida dentro da transação de gravação, por verificação de condição. Não há exclusão física de dados mestres (RN-30), o que elimina a necessidade de regras em cascata.
- **Numeração sem lacunas.** O contador anual é incrementado e o certificado é criado em uma única transação: ou as duas coisas acontecem, ou nenhuma (RN-14).

3.2.5 Cópia de segurança e recuperação

Na PoC, a recuperação apoia-se em duas propriedades da arquitetura: os originais e os PDFs emitidos estão no S3, com versionamento e bloqueio, e o processamento é determinístico. As tabelas são, portanto, reconstruíveis a partir dos arquivos. A recuperação contínua do DynamoDB (*point-in-time recovery*) não é ativada na PoC porque é cobrada por GB; em produção ela deve ser ligada — com 20 MB de dados o custo é de frações de centavo — para atender ao RNF-10 (RPO de até 24 horas e RTO de até 4 horas).

4. Requisitos de Segurança, Autenticação e Conformidade

4.1 Gestão de identidade e controle de acesso (IAM)

4.1.1 Modelo de identidade

Há três tipos de identidade, cada um com mecanismo próprio. **Pessoas que usam o sistema** são usuários do Amazon Cognito, organizados em grupos que correspondem aos perfis da AV01. Elas não têm usuário nem chave do IAM e nunca falam diretamente com o S3 ou com o DynamoDB: tudo passa pelo API Gateway, e o acesso a arquivos se dá por autorizações pré-assinadas, específicas e de curta duração. **Serviços internos** — as três funções — assumem papéis do IAM com permissões mínimas e credenciais temporárias, renovadas automaticamente; não existe senha ou chave de acesso gravada em código ou em configuração. **Pessoas que administram a conta** — os três integrantes do grupo, na PoC — usam usuários individuais com segundo fator; o usuário raiz é usado apenas na criação da conta, com segundo fator e sem chaves de acesso.

4.1.2 Perfis de operadores e auditores

Grupo (Cognito)	Pode	Não pode
`metrologista`	Solicitar upload; consultar calibrações e minutas; corrigir e reenviar arquivo em quarentena.	Aprovar ou emitir; cancelar certificado; ver a trilha de outros usuários.
`signatario`	Consultar minutas; aprovar ou devolver; baixar certificados emitidos.	Aprovar calibração em que é o técnico executante (RN-12); enviar arquivo; alterar dados.
`coordenador`	Consultar tudo; cancelar ou solicitar reemissão com justificativa (RN-15, RN-30); liberar bloqueio de padrão com justificativa.	Aprovar; alterar resultado; excluir registro.
`auditor`	Somente leitura: certificados emitidos, originais importados e trilha de auditoria.	Qualquer operação de escrita.
Público (sem login)	Verificar autenticidade por token: número, data, situação e hash.	Ver resultados, nomes ou baixar o PDF.

A autorização é aplicada em duas camadas. Na borda, o autorizador JWT do API Gateway exige token válido em todas as rotas, exceto a de verificação pública. Na função, cada rota confere o grupo do usuário antes de agir. A segregação de funções da RN-12 tem uma terceira camada, no dado: a gravação da aprovação é condicional a que o identificador do aprovador seja diferente do identificador do técnico registrado na calibração. Mesmo que um defeito na aplicação deixasse passar a checagem de perfil, o banco recusaria a gravação. Os tokens de acesso são configurados para expirar em 60 minutos, o que atende à sessão expirável do RNF-05, e a desativação de um usuário no Cognito impede novos acessos (RN-12, signatário inativo não assina).

4.1.3 Papéis dos serviços internos

Papel	Recurso	Ações permitidas	Deliberadamente negado
`role-fn-api`	Bucket de entrada, `uploads/*`	`s3:PutObject` (para assinar o upload)	Ler planilhas
`role-fn-api`	Bucket de certificados	`s3:GetObject` (para assinar o download)	Gravar ou excluir PDFs
`role-fn-api`	Tabela `calibracoes` e índices	`GetItem`, `Query`, `UpdateItem`	`Scan`, `DeleteItem`

Papel	Recurso	Ações permitidas	Deliberadamente negado
`role-fn-api`	Tabela `auditoria`	`PutItem`, `Query`	`UpdateItem`, `DeleteItem`
`role-fn-api`	Função `fn-certificado`	`lambda:InvokeFunction`	Invocar outras funções
`role-fn-ingestao`	Bucket de entrada	`s3:GetObject` em `uploads/*`; `s3:PutObject` em `quarentena/*`	Qualquer acesso ao bucket de certificados
`role-fn-ingestao`	Tabela `calibracoes`	`GetItem`, `Query`, `PutItem`, `UpdateItem`	`DeleteItem`, `Scan`
`role-fn-ingestao`	Tabela `auditoria`	`PutItem`	Ler, alterar, excluir
`role-fn-ingestao`	Fila de falhas, tópico SNS, `fn-certificado`	`sqs:SendMessage`, `sns:Publish`, `lambda:InvokeFunction`	Ler a fila
`role-fn-certificado`	Bucket de certificados	`s3:PutObject` e `s3:PutObjectRetention` em `minutas/*` e `emitidos/*`	`s3:DeleteObject`; dispensar o bloqueio de retenção
`role-fn-certificado`	Tabela `calibracoes`	`GetItem`, `Query`, `UpdateItem`, `PutItem`	`DeleteItem`, `Scan`
`role-fn-certificado`	Tabela `auditoria`; fila de falhas	`PutItem`; `sqs:SendMessage`	Qualquer acesso ao bucket de entrada

Todos os papéis recebem ainda a permissão de escrever logs no próprio grupo de logs, e nada mais. Três consequências desse desenho merecem destaque. Nenhuma função consegue excluir um certificado emitido ou um evento de auditoria, porque nenhum papel tem essas ações. A função que gera o documento não enxerga as planilhas, e a que lê as planilhas não enxerga os documentos: o comprometimento de uma não expõe o acervo da outra. E a trilha de auditoria é somente de inserção por permissão, não por convenção (RNF-04, RN-21).

Exemplo real de política — o papel da função de ingestão, com os nomes de recurso da PoC [os identificadores de conta são preenchidos na implantação]:

```
{
  "Version": "2012-10-17",
  "Statement": [
    { "Sid": "LerPlanilhasEnviadas",
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::schulz-poc-entrada/uploads/*" },
    { "Sid": "GravarQuarentena",
      "Effect": "Allow",
      "Action": "s3:PutObject",
      "Resource": "arn:aws:s3:::schulz-poc-entrada/quarentena/*" },
    { "Sid": "GravarCalibracoes",
      "Effect": "Allow",
      "Action": ["dynamodb:GetItem", "dynamodb:Query",
                 "dynamodb:PutItem", "dynamodb:UpdateItem"],
      "Resource": "arn:aws:dynamodb:sa-east-1:<conta>:table/calibracoes" },
    { "Sid": "AuditoriaSomenteInsercao",
      "Effect": "Allow",
      "Action": "dynamodb:PutItem",
      "Resource": "arn:aws:dynamodb:sa-east-1:<conta>:table/auditoria" },
    { "Sid": "EncadearEFalhar",
      "Effect": "Allow",
      "Action": ["lambda:InvokeFunction", "sqs:SendMessage", "sns:Publish"],
      "Resource": [
        "arn:aws:lambda:sa-east-1:<conta>:function:fn-certificado",
```

```
        "arn:aws:sqs:sa-east-1:<conta>:schulz-poc-falhas",
        "arn:aws:sns:sa-east-1:<conta>:schulz-poc-operacao" ] }
  ]
}
```

4.1.4 Políticas nos recursos e rastreabilidade administrativa

Além das políticas de identidade, os próprios recursos impõem regras. Os dois buckets têm o bloqueio de acesso público ativado e uma política que nega qualquer requisição sem TLS. A permissão para o S3 invocar a `fn-ingestao` é restrita ao bucket de entrada e à conta da PoC, de modo que nenhum outro bucket, de nenhuma outra conta, consegue disparar o pipeline. As ações administrativas — criação de papéis, alteração de políticas, mudança de configuração de bucket — ficam no histórico de eventos do CloudTrail, o que permite responder, em auditoria, quem alterou a infraestrutura e quando (RA-05, RA-06). Em produção, na conta da Schulz, o acesso administrativo deve ser federado ao diretório corporativo da empresa [VALIDAR com a TI da Schulz].

4.2 Segurança e proteção de dados (in-transit e at-rest)

4.2.1 Classificação dos dados

Dado	Classificação	Onde fica
Planilhas de medição e resultados	Confidencial — informação técnica da Schulz e de seus clientes	Bucket de entrada; tabela `calibracoes`
Certificados emitidos	Confidencial; registro de qualidade com guarda de 5 anos	Bucket de certificados, com Object Lock
Nome e matrícula de técnicos e signatários	Dado pessoal (LGPD)	Cognito; nome impresso no certificado; identificador opaco nas tabelas
Trilha de auditoria	Confidencial; evidência	Tabela `auditoria`, somente inserção
Dados de verificação pública	Público por desenho	Resposta da rota de verificação: número, data, situação e hash

4.2.2 Proteção em repouso (at-rest)

Todo dado armazenado é criptografado, sem exceção e sem ação do usuário. No **S3**, a criptografia no servidor com chaves gerenciadas pelo serviço (SSE-S3, AES-256) é aplicada a todos os objetos dos dois buckets; a política do bucket de certificados nega gravações que tentem dispensá-la. No **DynamoDB**, as duas tabelas são criptografadas por padrão com chave de propriedade da AWS, o que cobre também índices e cópias de segurança. Logs e mensagens em fila ficam igualmente criptografados nos serviços gerenciados. As chaves são guardadas e rotacionadas pela AWS, sem custo e sem operação pela equipe.

A opção por SSE-S3, e não por chave gerenciada pelo cliente no AWS KMS, é uma decisão de custo declarada: a chave própria custa US$ 1 por mês e não tem cota gratuita, o que violaria a restrição da PoC. O que se perde é o controle fino — política própria da chave e registro de cada uso dela. Para produção, o grupo recomenda migrar os dois buckets para SSE-KMS com chave do cliente e rotação automática anual, o que separa a permissão de acessar o arquivo da permissão de decifrá-lo.

Criptografia protege o sigilo; a **integridade** tem mecanismos próprios, que respondem ao achado mais grave da AV01, o de registros editáveis e não versionados (D-10, RA-06): o hash SHA-256 de cada PDF é gravado na tabela e impresso no documento (RNF-03); o versionamento do bucket preserva qualquer versão anterior; e o Object Lock impede sobrescrita e exclusão por 5 anos (DE-04). Um certificado alterado fora do sistema é detectável por qualquer pessoa pela rota de verificação.

4.2.3 Proteção em trânsito (in-transit)

Trecho	Proteção
Navegador → Cognito	HTTPS; senha nunca trafega pela aplicação do grupo
Navegador → API Gateway	HTTPS com TLS 1.2; não existe ponto de acesso HTTP
Navegador → S3 (upload e download)	HTTPS em endereço pré-assinado; política do bucket nega requisições sem TLS (`aws:SecureTransport`)
Funções → S3, DynamoDB, SQS, SNS	Chamadas autenticadas e assinadas, sobre TLS, aos pontos de acesso da própria região
SNS → e-mail	Mensagens de alerta sem dado técnico ou pessoal: apenas o identificador da calibração e o tipo de evento

O acesso seguro tem dois públicos. Os **clientes internos** autenticam-se com segundo fator e recebem, para cada download, um endereço pré-assinado que expira em 5 minutos e vale para um único arquivo; um endereço que vaze por e-mail perde a utilidade antes de ser reaproveitado. Os **clientes externos** — fornecedores como CDM, Usifer, Torque e Valente, e auditores — recebem o PDF da Metrologia pelo canal habitual e conferem a autenticidade pelo token impresso no documento, sem cadastro e sem acesso a nenhum dado além do necessário para a conferência. A rota pública tem limite de taxa e o token tem 32 caracteres aleatórios, o que inviabiliza a enumeração.

4.2.4 Autoria do certificado sem ICP-Brasil

Conforme DE-03, a PoC não usa certificado digital. A autoria é estabelecida pela cadeia: usuário autenticado com segundo fator → aprovação registrada com identificador, data e hora → nome do técnico executante e do signatário impressos no PDF → hash do documento gravado → evento na trilha somente de inserção. Isso corresponde a uma assinatura eletrônica baseada em autenticação, suficiente para o fluxo interno descrito pela empresa. A assinatura digital com certificado ICP-Brasil permanece no roteiro de evolução, e a arquitetura a comporta sem redesenho: é um passo adicional da `fn-certificado` antes da gravação.

4.2.5 Conformidade: LGPD e retenção

Os dados pessoais tratados limitam-se a nome, matrícula e perfil de técnicos e signatários (RN-35), o que responde ao risco RA-12 da AV01, em que esses dados circulavam em planilhas sem controle de acesso. As medidas são: minimização, com o identificador opaco nas tabelas e o nome apenas onde o documento o exige; acesso por perfil, com registro de quem consultou o quê (RN-24); nenhum dado pessoal em logs ou em mensagens de alerta; hospedagem na região de São Paulo, o que evita a transferência internacional de dados na operação normal; e descarte ao fim do prazo de guarda pelas regras de ciclo de vida. A base legal do tratamento e o prazo de guarda dos dados pessoais devem ser confirmados com o encarregado de dados da Schulz [VALIDAR]. O prazo de 5 anos da DE-04 aplica-se ao certificado e ao arquivo de origem; como o nome do técnico é parte do certificado, ele segue o mesmo prazo. A confidencialidade de informação de terceiros apontada

em RA-11 é tratada pelo isolamento por calibração: cada arquivo fica sob o identificador da sua calibração e não existe modelo compartilhado que carregue dados de outro cliente.

5. Rastreabilidade com a Entrega 01

Decisão de arquitetura	Requisitos e regras atendidos	Dor, anomalia ou risco tratado
Upload como única entrada, por autorização pré-assinada	RF-01, RN-26, RNF-05	D-02, AN-25, RA-10
Pipeline serverless disparado por evento	RNF-01, RNF-12, RF-02 a RF-09	D-01, D-14
Hash do arquivo com gravação condicional	RN-20, RN-22	D-09, AN-06
Quarentena separada de falha técnica	RF-04, UC-06	AN-03, AN-05
Cálculo em função versionada, orçamento persistido	RF-06, RF-07, RNF-08, RNF-09, RN-31, RN-36	D-04, D-08, AN-17, RA-05
Bucket de certificados com Object Lock e versões	RNF-03, RN-15, RN-22, RN-30	D-10, RA-06
Regras de ciclo de vida de 5 anos	RN-35, DE-04	RA-10, PV-09
Cognito com grupos e segundo fator	RNF-05, RF-12, RN-12, RN-21	AN-22, RA-09
Tabela de auditoria somente de inserção	RF-14, RNF-04, RN-21, RN-24	D-10, RA-06
Verificação pública por token e hash	RF-16, RNF-03	RA-07
Criptografia em repouso e TLS obrigatório	RNF-06	RA-10, RA-11
Minimização de dados pessoais, região São Paulo	RNF-07, RN-24, RN-35	RA-12
Fila de falhas, alarmes e notificação	RNF-10	AN-03, D-13

Dois requisitos da AV01 ficam explicitamente fora desta arquitetura, por definição da empresa: a exportação do registro para o LightLab (RF-19), em razão de DE-01, e a assinatura com certificado ICP-Brasil (PV-10), em razão de DE-03. Ambos permanecem no roteiro de evolução, junto com o painel operacional (RF-20) e o histórico de tendência (RF-22), que a modelagem da Seção 3.2 já comporta pelos índices GSI1 e GSI2.

6. Premissas, restrições e pontos a validar

ID	Tipo	Item	Impacto se a premissa for falsa
PV-01	Respondido	Integração com LightLab — não haverá (DE-01)	—
PV-08	Respondido	Exportação nativa do Calypso — fora do escopo (DE-01)	—
PV-09	Respondido	Retenção de 5 anos com ciclo de vida no storage (DE-04)	—
PV-10	Respondido	ICP-Brasil não é necessária na PoC (DE-03)	—
PV-05	[PREMISSA]	Volume de 137 certificados por ano	A matriz suporta 10 vezes esse volume abaixo de 1% das cotas; só altera o ROI da Entrega 05
PV-17	[PREMISSA]	A PoC roda em conta AWS nova e dedicada, no plano gratuito	Em conta antiga, S3 e API Gateway seriam cobrados: cerca de US$ 0,03 por mês. Em ambiente de laboratório acadêmico, a criação de papéis e de orçamentos pode estar bloqueada
PV-18	[VALIDAR]	Tarifas de S3 e API Gateway em sa-east-1, na AWS	Usadas tarifas-teto; o consumo de

ID	Tipo	Item	Impacto se a premissa for falsa
		Pricing Calculator	créditos estimado é um limite superior
PV-19	[PREMISSA]	Layout exato da planilha sanitizada (abas e colunas) como contrato de entrada, a fixar na Entrega 03	Altera apenas a etapa E5 do pipeline
PV-20	[VALIDAR]	Base legal e prazo de guarda dos dados pessoais, com o encarregado de dados da Schulz	Pode exigir prazo distinto para o identificador do usuário nas tabelas
PV-21	[VALIDAR]	A aprovação pelo signatário é obrigatória antes da emissão, ou a empresa quer emissão totalmente automática?	Sem aprovação, os passos 8 e 9 se fundem e a emissão ocorre logo após a ingestão; o desenho suporta os dois modos por configuração
PV-22	[PREMISSA]	Tempos de execução das funções (8 s e 6 s) são tetos estimados	Serão medidos na Entrega 03; mesmo 10 vezes maiores ficariam abaixo de 7% da cota, no cenário 10×
PV-23	[RESTRIÇÃO]	Custo de R$ 0,00 na PoC; nenhuma conversão para plano pago sem decisão registrada	Define a exclusão de KMS com chave própria, RDS e recuperação contínua do DynamoDB

7. Referências consultadas

Todas as páginas foram consultadas em 02/10/2026.

- AWS. *AWS Free Tier update: New customers can get started and explore AWS with up to $200 in credits* (15/07/2025). https://aws.amazon.com/blogs/aws/aws-free-tier-update-new-customers-can-get-started-and-explore-aws-with-up-to-200-in-credits/
- AWS. *AWS Free Tier* e *Free Tier FAQs*. https://aws.amazon.com/free/ · https://aws.amazon.com/free/free-tier-faqs/
- AWS Billing. *Using the AWS Free Tier* e *Choosing an AWS Free Tier plan*. https://docs.aws.amazon.com/awsaccountbilling/latest/aboutv2/free-tier.html · https://docs.aws.amazon.com/awsaccountbilling/latest/aboutv2/free-tier-plans.html
- AWS Lambda. *Pricing*; *Lambda quotas*; *Using AWS Lambda with Amazon S3*; *Asynchronous invocation — error handling*. https://aws.amazon.com/lambda/pricing/ · https://docs.aws.amazon.com/lambda/latest/dg/gettingstarted-limits.html · https://docs.aws.amazon.com/lambda/latest/dg/with-s3.html · https://docs.aws.amazon.com/lambda/latest/dg/invocation-async-error-handling.html
- Amazon DynamoDB. *Pricing* e *Encryption at rest*. https://aws.amazon.com/dynamodb/pricing/on-demand/ · https://docs.aws.amazon.com/amazondynamodb/latest/developerguide/EncryptionAtRest.html
- Amazon S3. *Pricing*; *Lifecycle transition general considerations*; *Object Lock*; *Protecting data with encryption*. https://aws.amazon.com/s3/pricing/ · https://docs.aws.amazon.com/AmazonS3/latest/userguide/lifecycle-transition-general-considerations.html · https://docs.aws.amazon.com/AmazonS3/latest/userguide/object-lock.html · https://docs.aws.amazon.com/AmazonS3/latest/userguide/UsingEncryption.html
- Amazon Cognito, Amazon API Gateway, Amazon SQS, Amazon SNS, AWS KMS, Amazon CloudWatch e AWS Budgets. Páginas de preços. https://aws.amazon.com/cognito/pricing/ · https://aws.amazon.com/api-gateway/pricing/ · https://aws.amazon.com/sqs/pricing/ ·

https://aws.amazon.com/sns/faqs/ · https://aws.amazon.com/kms/pricing/ · https://aws.amazon.com/cloudwatch/pricing/ · https://aws.amazon.com/aws-cost-management/aws-budgets/pricing/

- Grupo 39. *Identificação do Problema e Levantamento de Requisitos* (Entrega AV1, 15/09/2026).
- Schulz S.A. Orientações de escopo para a Entrega 02, recebidas em 17/09/2026.